

Armongate Sistem İncelemesi ve Yeni PDKS Gereksinimleri

Mevcut ürün gözlemlerinin doğrulanabilirlik açısından düzeltilmiş analizi, eksik iş alanları ve Faydam PDKS için önerilen ürün kapsamı.

Rapor türü	Sistem inceleme ve gereksinim analizi
Hazırlayan	Elif Kara · Staj Projesi
Tarih	14 Temmuz 2026
Durum	Düzeltilmiş profesyonel sürüm

GİZLİLİK NOTU

Bu rapor, kullanıcı tarafından sağlanan ekran ve kullanım gözlemlerine dayanır. Armongate'in yayınlanmamış kaynak kodu, veritabanı şeması veya özel altyapı dokümanı incelenmemiştir. Bu nedenle doğrulanamayan teknik ayrıntılar kesin bulgu olarak sunulmamıştır.

1. Yönetici özeti

Armongate, erişim kontrolü, personel devam takibi, ziyaretçi yönetimi, donanım izleme ve raporlama işlevlerini aynı yönetim deneyiminde birleştiren kapsamlı bir ürün görünümü sunmaktadır. İncelenen ekranlar, yeni Faydam PDKS için değerli bir referans oluşturmakla birlikte yalnızca arayüz gözlemlerinden altyapı teknolojisi veya güvenlik seviyesi hakkında kesin sonuç çıkarılamaz.

İlk raporun güçlü yönü, modülleri ayrıntılı biçimde sınıflandırmasıdır. Temel düzeltme ihtiyacı ise gözlem, teknik kanıt ve varsayımın aynı kesinlik seviyesinde yazılmış olmasıdır. Bu sürümde iddialar yeniden sınıflandırılmış; PDKS'nin bordro, vardiya, izin, veri bütünlüğü, KVKK ve denetim gereksinimleri eklenmiştir.

Öncelikli sonuçlar

- Faydam PDKS, ham geçiş olayları ile hesaplanmış puantaj sonuçlarını ayrı tutmalıdır.
- Web paneli ve mobil API ayrı istemci sınırlarına sahip olmalı; ortak iş kuralları Core katmanında paylaşılmalıdır.
- Rol kontrolü tek başına yeterli değildir; şirket, işyeri, bölüm ve kendi kaydı gibi veri kapsamı da uygulanmalıdır.
- Mobil olaylar çevrimdışı kuyruk, benzersiz olay kimliği ve tekrar gönderim desteğiyle idempotent işlenmelidir.
- Her manuel düzeltme ve yönetici kararı değişmez denetim iziyle saklanmalıdır.

Raporun sınırı

Bu çalışma bir ürün ve arayüz incelemesidir; penetrasyon testi, kaynak kod denetimi, hukuki uygunluk görüşü veya Armongate'in resmi teknik mimari belgesi değildir.

2. İnceleme yöntemi ve kanıt sınıfları

Profesyonel bir sistem incelemesinde her tespit, dayandığı kanıtlarla birlikte yazılmalıdır. Bu raporda aşağıdaki sınıflandırma kullanılmıştır:

Sınıf	Tanım	Kullanım örneği
Ekran gözlemi	Arayüzde doğrudan görülen alan, menü veya davranış.	Raporlar menüsünde PDKS ve donanım kategorileri bulunması.
Ağ trafiği bulgusu	Tarayıcı geliştirici araçlarında görülen istek, protokol veya alan.	Bir WebSocket bağlantısının URL ve mesajlarıyla doğrulanması.
Dokümantasyon bilgisi	Üreticinin resmi dokümanında açıklanan özellik.	Desteklenen kart/okuyucu protokolleri.
Varsayım	Mevcut kanıtlarla doğrulanamayan ancak olası yorum.	Ürünün tamamen ACaaS modeliyle sunulduğu iddiası.

İlk rapordaki kesinlik düzeltmeleri

İlk ifade	Düzeltilmiş ifade
Sistem ACaaS modelinde çalışır.	Sistem merkezi servis kullanan bir yapı izlenimi vermektedir; dağıtım ve lisans modeli resmi dokümanla doğrulanmalıdır.
AppInitializerService WebSocket bağlantısını kurar.	Bu isim geliştirici araçlarında veya kaynak çıktısında görülmüşse ağ trafiği bulgusu olarak, aksi halde varsayım olarak belirtilmelidir.
Giriş verileri şifrelenmiş biçimde gönderilir.	HTTPS doğrulandıysa verilerin TLS ile aktarım sırasında korunduğu söylenebilir; parolanın uygulama düzeyinde ayrıca şifrelenip şifrelenmediği bilinmemektedir.
Merkezi API verilerin güvenli yerde tutulduğunu kanıtlar.	Merkezi API kullanımı veri konumunu ve güvenlik kontrollerini tek başına kanıtlamaz.
Tekil ID veri bütünlüğünün kanıtıdır.	Tekil ID bir iş anahtarı gereksinimini gösterir; benzersiz indeks ve kısıtlar ayrıca doğrulanmalıdır.

3. Gözlemlenen ürün kapsamı

Aşağıdaki modüller, kullanıcının Armongate incelemesinde gördüğü ekran ve menülere göre yeniden düzenlenmiştir. Teknik uygulama ayrıntıları doğrulanmadıkça ürün davranışı seviyesinde açıklanmıştır.

Kimlik doğrulama ve hesap yönetimi

- Kullanıcı adı/e-posta ve parola ile oturum açma.
- Kişisel bilgi, parola, cihaz ve bildirim tercihlerinin yönetimi.
- Rol veya yetki alanına göre menü ve işlem erişimi.

Erişim kontrolü

- Kullanıcı, kimlik, grup, bölge ve erişim noktası tanımları.
- Kapı, turnike veya bariyer geçişlerinin yetkiye göre değerlendirilmesi.
- Gerçekleşen ve reddedilen geçişlerin zaman, kullanıcı ve bölgeyle kaydı.

PDKS ve izin yönetimi

- Giriş-çıkış hareketlerinden devam durumu üretme.
- Geç başlama, erken çıkma, eksik çalışma ve fazla çalışma sınıfları.
- Çalışma planları ve izin taleplerinin onay süreci.

Ziyaretçi, donanım ve raporlar

- Ziyaretçi ön kayıt, aktif ziyaret ve ziyaret geçmişi.
- Okuyucu/terminal olayları, bağlantı ve arıza görünümü.
- Erişim, PDKS, ziyaretçi, donanım ve denetim raporları.
- Zamanlanmış rapor veya görevlerin otomatik çalıştırılması.

4. Uçtan uca iş akışları

4.1 Personel tanımlama ve yetkilendirme

Adım	İşlem	Beklenen kontrol
1	Personel kaydı oluşturulur.	Sicil/e-posta benzersizliği, zorunlu alanlar.
2	Şirket, işyeri, bölüm ve pozisyon atanır.	Organizasyon kapsamı ve geçerlilik tarihleri.
3	Vardiya/takvim atanır.	Çakışan atama ve gece vardiyası kontrolü.
4	Kart veya mobil kimlik tanımlanır.	Kimlik benzersizliği, aktiflik ve süre.
5	Bölge/kapı yetkisi verilir.	Rol, grup, zaman profili ve istisnalar.
6	İşlem denetim izine yazılır.	Kim, ne zaman, hangi eski/yeni değer.

4.2 Mobil geçiş olayı

- Mobil uygulama kullanıcı oturumunu kısa ömürlü access token ile doğrular.
- Cihaz, olay zamanı, bölge ve benzersiz deviceEventId üretir.
- Bağlantı yoksa olay şifreli yerel kuyrukta saklanır.
- Sunucu aynı deviceEventId değerini ikinci kez işlemez.
- Ham olay değişmeden saklanır; puantaj motoru bu olaydan ayrı sonuç üretir.

4.3 İzin talebi ve onay

- Personel mobil uygulamadan izin türü, tarih ve gerekçe gönderir.
- Sistem tarih sırası, geçmiş tarih, çakışma ve hak kontrolü yapar.
- Yetkili yönetici yalnızca kendi veri kapsamındaki talebi görür.
- Yönetici kendi talebini onaylayamaz; karar tarihi ve notu kaydedilir.
- Onaylanan izin puantaj hesabına otomatik yansır.

5. Rol ve veri kapsamı modeli

Rol tabanlı erişim kontrolü, işlemin yapılabilirliğini belirler. Kurumsal PDKS'de ayrıca kullanıcının hangi personel kayıtları üzerinde işlem yapabileceği tanımlanmalıdır.

Rol	Temel yetki	Önerilen veri kapsamı
Sistem yöneticisi	Sistem ayarları, roller, entegrasyon ve tüm modüller.	Yetkilendirildiği şirketler; kritik işlemler için ek doğrulama.
İK / PDKS sorumlusu	Personel, vardiya, izin, düzeltme ve rapor işlemleri.	Atanmış şirket/işyeri/bölmeler.
Bölüm yöneticisi	Ekip devamlılığı ve izin onayı.	Yönettiği organizasyon ağacı.
Güvenlik görevlisi	Geçiş ve ziyaretçi operasyonları.	Atanmış tesis ve erişim noktaları.
Personel	Kendi profil, puantaj ve izin işlemleri.	Yalnızca kendi kaydı.

Yetki matrisi örneği

İşlem	Admin	İK	Yönetici	Personel
Personel oluşturma	Evet	Kapsamında	Hayır	Hayır
Puantaj görüntüleme	Tümü	Kapsamında	Ekibi	Kendi
İzin onaylama	Evet	Kapsamında	Ekibi	Hayır
Ham olayı değiştirme	Hayır*	Hayır*	Hayır	Hayır
Düzeltilme kaydı	Evet	Kapsamında	Talep	Talep
Denetim raporu	Evet	Kapsamında	Hayır	Hayır

* Ham olay silinmemeli veya üzerine yazılmamalıdır. Hatalı kayıt, yeni bir düzeltme kaydı ve gerekçeyle etkisizleştirilmelidir.

6. İlk raporda eksik kalan PDKS alanları

Alan	Neden gereklidir	Asgari gereksinim
Organizasyon	Yetki ve rapor kapsamının temelidir.	Şirket, işyeri, bölüm, pozisyon, yönetici ağacı.
Vardiya	Puantaj hesaplamasının girdisidir.	Gece vardiyası, tolerans, mola, esnek vardiya, geçerlilik tarihi.
Takvim	Tatil ve çalışma günlerini ayırır.	Resmi tatil, hafta tatili, yarım gün, özel gün.
Puantaj motoru	Ham olayları iş sonucuna dönüştürür.	Eksik/çift basım, geç/erken, fazla mesai, vardiya kesişimi.
Düzeltilme akışı	Hatalı basımlar kaçınılmazdır.	Talep, gerekçe, ek belge, çok seviyeli onay, eski/yeni değer.
Bordro entegrasyonu	Sonuçların ücret hesabına aktarımı gerekir.	Dönem kilidi, dışa aktarım, yeniden hesaplama ve mutabakat.
Terminal dayanıklılığı	Ağ kesintisi veri kaybına yol açmamalıdır.	Offline tampon, tekrar deneme, sıra ve tekilleştirme.
Veri yaşam döngüsü	Kişisel veriler süresiz tutulmamalıdır.	Saklama politikası, arşiv, anonimleştirme ve silme kaydı.

7. Önerilen Faydam PDKS mimarisi

Yönetici tarafından belirlenen dört projeli çözüm yapısı korunmalıdır. Web ve mobil API birbirini referanslamaz; ikisi de ortak Core sözleşmeleri ve Data uygulamaları üzerinden çalışır.

Proje	Sorumluluk	İçermemesi gerekenler
FaydamPDKS.Web	MVC/Razor paneli, web controller'ları, cookie oturumu.	Mobil JWT sözleşmeleri veya doğrudan migration.
FaydamPDKS.Api	Sürümlenmiş mobil API, JWT/refresh token, OpenAPI.	Razor görünümü veya web cookie akışı.
FaydamPDKS.Core	Model, DTO, enum, interface ve saf iş kuralları.	DbContext, ControllerBase veya sunum bağımlılığı.
FaydamPDKS.Data	DbContext, EF eşlemeleri, repository ve migrations.	HTTP controller veya kullanıcı arayüzü.

Güvenlik kararları

- Web oturumunda HttpOnly, Secure ve SameSite cookie; mobilde kısa ömürlü JWT ve döndürülen refresh token.
- Parola, veritabanı bağlantısı ve JWT anahtarı kaynak kodda değil secret store veya ortam değişkeninde tutulur.
- Mobil refresh token veritabanında açık metin değil güçlü hash olarak saklanır.
- Giriş uçlarında rate limit; tüm değiştirici işlemlerde doğrulama ve denetim izi uygulanır.
- Web formlarında antiforgery; API'de tutarlı 400/401/403/409/429 hata sözleşmesi kullanılır.

8. Kullanılabilirlik ve erişilebilirlik değerlendirmesi

İlk rapordaki boş veri ekranı, toplu kullanıcı yükleme, organizasyon ağacı ve başarısız zamanlanmış görev bildirimi önerileri korunmuştur. Bunlara aşağıdaki tasarım ilkeleri eklenmelidir:

- Boş durumlar yalnızca 'veri yok' dememeli; yetkili kullanıcıya sonraki güvenli eylemi göstermelidir.
- Filtreler URL veya kalıcı sorgu durumuyla paylaşılabilir olmalı; tarih ve organizasyon kapsamı açıkça görünmelidir.
- Renk tek durum göstergesi olmamalı; metin, ikon ve erişilebilir etiket birlikte kullanılmalıdır.
- Tüm formlar klavye ile kullanılmalı, görünür odak ve alan bazlı hata mesajı içermelidir.
- Uzun tablolar mobilde öncelikli sütunlara indirgenmeli; dışa aktarım arka planda hazırlanmalıdır.
- Kritik onay ve toplu işlem öncesinde kapsam ve etkilenen kayıt sayısı gösterilmelidir.

SEO hakkında doğru yaklaşım

PDKS yönetim paneli oturum gerektiren özel bir uygulamadır; bu ekranların arama motorlarında indekslenmesi istenmez. Bu nedenle panel ve giriş ekranlarında noindex, nofollow kullanılmalıdır. Buradaki kalite hedefi klasik SEO'dan çok semantik HTML, erişilebilirlik, hızlı yükleme ve güvenli başlıklardır. Yalnızca herkese açık bir ürün tanıtım sitesi oluşturulursa canonical URL, açıklama, Open Graph ve yapılandırılmış veri uygulanmalıdır.

9. Riskler ve kontrol önerileri

Risk	Etki	Önerilen kontrol
Mükerrer mobil olay	Çift giriş/çıkış ve hatalı puantaj.	Benzersiz deviceEventId ve veritabanı unique index.
Saat dilimi hatası	Yanlış gün/vardiya hesabı.	UTC saklama, kullanıcı saat diliminde sunum, DST testleri.
Refresh token sızıntısı	Uzun süreli hesap ele geçirme.	Hash saklama, rotasyon, cihaz bazlı iptal ve yeniden kullanım tespiti.
Yetki kapsamı hatası	Başka bölümün kişisel verisine erişim.	Rol + veri kapsamı politikası ve entegrasyon testleri.
Ham olayın değiştirilmesi	Denetim ve bordro güvenilirliğinin kaybı.	Append-only olay, düzeltme kaydı ve audit log.
Ağ kesintisi	Geçiş veya puantaj olayının kaybı.	Offline kuyruk, tekrar deneme, gözlemlenebilir senkronizasyon.
Toplu işlem hatası	Çok sayıda yanlış personel/puantaj kaydı.	Ön izleme, doğrulama raporu, idempotent import ve geri alma planı.

KVKK ve mahremiyet

PDKS verileri çalışan davranışı ve konumuyla ilişkilendirilebilen kişisel verilerdir. İşleme amacı, erişim rolleri, saklama süresi ve çalışan bilgilendirmesi kurumun hukuk/uyum sorumlularıyla belirlenmelidir. Biyometrik veri kullanılacaksa daha yüksek risk ve özel nitelikli veri gereksinimleri ayrıca değerlendirilmelidir.

10. Aşamalı geliştirme planı

Aşama	Kapsam	Çıkış ölçütü
1 · Temel	Dört proje, güvenli kimlik, roller, kullanıcı ve organizasyon.	Temiz derleme, migration, yetki testleri.
2 · Olay hattı	Terminal/mobil olay, idempotency, offline senkronizasyon.	Tekrar gönderimde tek kayıt; izlenebilir hata.
3 · Puantaj	Vardiya, takvim, geç/erken, eksik ve fazla mesai.	Kural senaryoları otomatik testlerle doğrulanmış.
4 · İzin/onay	Mobil talep, web onay, kapsam ve self-approval engeli.	Uçtan uca durum geçişleri ve audit.
5 · Rapor/bordro	Dönem, kilit, dışa aktarım ve mutabakat.	Aynı girdiden tekrarlanabilir sonuç.
6 · Operasyon	Gözlemlenebilirlik, yedekleme, güvenlik ve performans.	Yük testi, geri yükleme denemesi, güvenlik kontrol listesi.

Başarı ölçütleri

- Aynı ham olay kümesi aynı kural sürümünde aynı puantaj sonucunu üretir.
- Kritik işlem için kim, ne zaman, neyi değiştirdi sorusu cevaplanabilir.
- Mobil ağ kesintisinden sonra veri kaybı ve mükerrer kayıt oluşmaz.
- Yetkisiz kullanıcı başka personelin profil, puantaj veya izin verisini göremez.
- Web ve mobil sözleşmeler otomatik test ve OpenAPI ile doğrulanır.

11. Sonuç

Armongate incelemesi, Faydam PDKS'nin modül kapsamını belirlemek için güçlü bir başlangıçtır. İlk rapordaki ana eksik, teknik iddiaların kanıt seviyesi belirtilmeden kesin sonuç gibi sunulması ve puantajın bordro/operasyon ayrıntılarının yeterince ele alınmamasıdır.

Önerilen Faydam PDKS; gösterge panelinden ibaret olmayan, ham olay bütünlüğünü koruyan, vardiya ve izin kurallarını test edilebilir biçimde uygulayan, mobil çevrimdışı davranışı yöneten ve tüm yönetici kararlarını denetlenebilir kılan bir sistem olarak geliştirilmelidir.

Bu rapor, ürün kapsamı ve mimari yön için temel kabul edilmelidir. Her geliştirme aşamasında gereksinimler test senaryolarına dönüştürülmeli; güvenlik, KVKK ve bordro kuralları ilgili kurum paydaşlarıyla doğrulanmalıdır.

Hazırlanan ek çıktılar	Konum
Mobil API entegrasyon rehberi	docs/MOBIL-API-ENTTEGRASYON-REHBERI.md
Mimari ve yol haritası	docs/ARMONGATE-INCELEME-VE-PDKS-YOL-HARITASI.md
Uygulama çözümü	FaydamPdkDemo.sln
Otomatik testler	FaydamPdkDemo.Core.Tests